

CAPÍTULO 4 · RESUMO DE ESTUDO

CRIPTOGRAFIA E PROTEÇÃO DE DADOS

Criptografia simétrica e assimétrica, assinatura digital, certificados digitais e a ICP-Brasil, e as regulamentações de proteção de dados (LGPD, GDPR) com privacy by design e DPIA — condensado para revisão antes da prova.

Curso Educação a Distância · Segurança e Auditoria de Sistemas de Informação

Base Nist, IETF, ABNT NBR ISO/IEC 27001/27701, ITI, LGPD (Lei 13.709/2018), GDPR (UE 2016/679)

01 – Simétrica & assimétrica

02 – Assinatura digital

03 – Certificados & ICP

04 – LGPD, GDPR & privacy

Termos-chave

Revisão rápida

01

CRIPTOGRAFIA SIMÉTRICA E ASSIMÉTRICA

Criptografia (do grego, "escrever em códigos") transforma dados legíveis em **texto cifrado**. A **cifragem** oculta a informação; a **decifragem** a recupera — sempre por meio de uma **chave criptográfica**, o elemento central de segurança do processo.

CRIPTOGRAFIA SIMÉTRICA

1 chave — cifra e decifra

Mesma chave secreta usada nas duas pontas. Alto desempenho, ideal para grandes volumes de dados. Desafio: distribuir a chave com segurança entre os participantes.

AES — padrão em blocos

ChaCha20 / Salsa20 — fluxo

CRIPTOGRAFIA ASSIMÉTRICA

2 chaves — pública + privada

Par de chaves matematicamente relacionadas. Resolve o problema da distribuição prévia, mas é mais custosa: usada para autenticação, assinatura e troca de chave de sessão.

RSA

ECDSA — curvas elípticas

Kyber / Dilithium — pós-quântico

DES / 3DES – descontinuados

CONFIDENCIALIDADE X AUTENTICIDADE

Cifrar com a **chave privada** do emissor → garante **autenticidade** (prova quem enviou). Cifrar com a **chave pública** do destinatário → garante **confidencialidade** (só ele decifra). O protocolo **TLS/HTTPS** combina os dois modelos: assimétrica na negociação inicial (autenticação do servidor), simétrica (AES-GCM, ChaCha20-Poly1305) para o tráfego. O TLS 1.3 introduz o *Forward Secrecy*: uma chave privada comprometida no futuro não expõe sessões passadas.

02

ASSINATURA DIGITAL

Combina criptografia assimétrica com uma **função de hash** para garantir autenticidade e integridade de documentos eletrônicos — o equivalente digital de uma impressão digital, exclusiva para cada conteúdo.

assinar • 1

GERAR O RESUMO (HASH)

O algoritmo de hash calcula o resumo criptográfico do documento — mais rápido que cifrar o documento inteiro.

58f197e ... 442d18db0bc

assinar • 2

CIFRAR COM A CHAVE PRIVADA

O resumo é cifrado com a chave privada do remetente. O resultado é a assinatura digital, anexada ao documento.

8e5a1bc ... f0efa1d888e84fa
cf

verificar • 3

RECALCULAR E DECIFRAR

O destinatário recalcula o hash do documento recebido e decifra a assinatura com a chave pública do remetente.

verificar • 4

COMPARAR OS RESUMOS

Se os dois resumos coincidem, o documento está íntegro e a assinatura é autêntica. Se não, houve alteração.

03

CERTIFICADOS DIGITAIS E INFRAESTRUTURA DE CHAVES PÚBLICAS (ICP)

A ICP (public key infrastructure — PKI) é o conjunto de políticas, procedimentos, pessoas, hardware, software e entidades que emitem, gerenciam, armazenam, distribuem, revogam e validam certificados digitais — a cadeia de confiança que garante que uma chave pública realmente pertence a quem afirma ser seu titular.

COMPONENTE	FUNÇÃO
Certificado digital	Documento eletrônico com nome do titular, chave pública, validade, AC emissora e assinatura da AC.
AC (autoridade certificadora)	Emite, renova, revoga e assina digitalmente os certificados.
AR (autoridade de registro)	Verifica a identidade do solicitante antes da emissão do certificado.
Repositórios / CRL	Armazenam certificados emitidos e listas de certificados revogados, para consulta de validade.
OCSF	Protocolo que permite verificar em tempo real se um certificado está ativo, expirado ou revogado.

ICP-BRASIL

Modelo de **raiz única**: o **ITI** (Instituto Nacional de Tecnologia da Informação) exerce o papel de **AC-Raiz**, credenciando e supervisionando as ACs subordinadas (ex.: Correios, Serasa Experian, Certisign, Valid). A validade jurídica das assinaturas eletrônicas no Brasil vem da Medida Provisória nº 2.200-2/2001. Desde 2024, a ICP-Brasil encerrou a emissão de certificados SSL/TLS para websites — hoje regulados por CAs internacionais.

A1

Armazenamento: no computador, servidor ou dispositivo móvel.
Validade: até 1 ano.

A3

Armazenamento: mídia externa — token USB, cartão inteligente ou HSM em nuvem.
Validade: 1 a 5 anos.

Usado em automação, como emissão de notas fiscais eletrônicas.

Chave privada fora do alcance do sistema operacional — proteção superior.

04

REGULAMENTAÇÕES DE PROTEÇÃO DE DADOS

O crescimento na coleta e no processamento de dados pessoais trouxe exigências legais explícitas para as empresas, no Brasil e no mundo.

REGULAMENTAÇÃO	PRINCIPAIS PONTOS
LGPD (Brasil)	Lei 13.709/2018. Direitos de acesso, retificação, exclusão e portabilidade; exige consentimento explícito para certos tratamentos; fiscalizada pela Autoridade Nacional de Proteção de Dados (ANPD).
GDPR (União Europeia)	Regulamento 2016/679, uma das legislações mais rigorosas do mundo. Introduce privacy by design, privacy by default, direito ao esquecimento, portabilidade de dados e notificação de violações em até 72 horas.
ISO/IEC 27001 / 27002 / 27005	Diretrizes para gestão de segurança da informação e análise de riscos (base técnica geral).
ISO/IEC 27701	Extensão da 27001 com requisitos específicos para um Sistema de Gestão de Informações de Privacidade (SGIP).

PRIVACY BY DESIGN & DPIA

Privacy by design (Ann Cavoukian) determina que a privacidade seja incorporada desde as primeiras fases de desenvolvimento de sistemas — com controles técnicos e organizacionais preventivos. A **DPIA** (data protection impact assessment) identifica, avalia e mitiga riscos à privacidade antes ou durante o tratamento de dados — exigida pelo art. 35 do GDPR e recomendada pelo art. 38 da LGPD. Controles recomendados pela ISO/IEC 27701 incluem **criptografia, pseudonimização e anonimização**.



TERMOS-CHAVE

Vocabulário que costuma aparecer em questões de múltipla escolha.

Texto cifrado

Informação transformada, ilegível sem a chave correta.

Forward secrecy

Propriedade do TLS 1.3: uma chave comprometida no futuro não expõe sessões passadas.

CRL

Lista de certificados revogados.

Pseudonimização

Substitui dados identificáveis por identificadores artificiais, reduzindo o risco em caso de vazamento.

SGIP

Sistema de Gestão de Informações de Privacidade — escopo da ISO/IEC 27701.

Resumo criptográfico

Saída de uma função de hash aplicada a um documento; muda por completo se o conteúdo mudar.

AC-Raiz

Autoridade certificadora no topo da cadeia de confiança (no Brasil, o ITI).

ANPD

Autoridade Nacional de Proteção de Dados — fiscaliza e regulamenta a LGPD.

Anonimização

Remove definitivamente a possibilidade de identificar o titular dos dados.

Criptografia pós-quântica

Algoritmos (Kyber, Dilithium) em padronização para resistir a ataques de computadores quânticos.



REVISÃO RÁPIDA ANTES DA PROVA

Confira se você consegue responder a cada ponto sem consultar o texto.



Explicar a diferença entre criptografia simétrica e assimétrica quanto ao número de chaves e ao desempenho.

- ☐ Dizer qual chave se usa para garantir autenticidade e qual para garantir confidencialidade.
- ☐ Explicar por que o TLS/HTTPS usa os dois modelos de criptografia juntos.
- ☐ Descrever os 4 passos da assinatura digital: hash → cifrar com chave privada → recalculando hash → comparar.
- ☐ Explicar o papel da AC e da AR dentro da ICP.
- ☐ Dizer quem é a AC-Raiz da ICP-Brasil e o que essa função implica.
- ☐ Diferenciar certificado A1 de A3 quanto a armazenamento e validade.
- ☐ Comparar LGPD e GDPR quanto aos direitos e prazos que estabelecem.
- ☐ Explicar o que é privacy by design e quando a DPIA deve ser aplicada.
- ☐ Explicar o que a ISO/IEC 27701 acrescenta em relação à ISO/IEC 27001.



REFERÊNCIAS DO CAPÍTULO

ABNT. NBR ISO/IEC 27001:2024; NBR ISO/IEC 27701:2019 — Extensão para gestão da privacidade da informação.

BRASIL. Lei nº 13.709/2018 (LGPD); Medida Provisória nº 2.200-2/2001 (ICP-Brasil); ITI — Certificado Digital, Entes da ICP-Brasil, Certificação Digital (2017; 2020a; 2020b; 2024).

CAVOUKIAN, Ann. Privacy by design: the 7 foundational principles. Toronto, 2011.

EUROPEAN UNION. Regulation (EU) 2016/679 (GDPR); When is a DPIA required?

FORTINET; SSL.com. O que é infraestrutura de chave pública (PKI)? 2024–2025.

IETF. RFC 7905 ChaCha20-Poly1305; RFC 8017 PKCS #1 (RSA); RFC 8446 TLS 1.3.

Nist. FIPS 186-5 Digital Signature Standard (2023); SP 800-131A rev. 2 (2019); status report on post-quantum cryptography (2025).

SERPRO. Quem vai regular a LGPD? 2025.

SULLIVAN, N. Do the ChaCha: better mobile performance with cryptography. Cloudflare Blog, 2015.

Resumo gerado a partir do capítulo "Criptografia e proteção de dados" (SEG_AUD_SIS_04_ACE_2025) para revisão de prova.